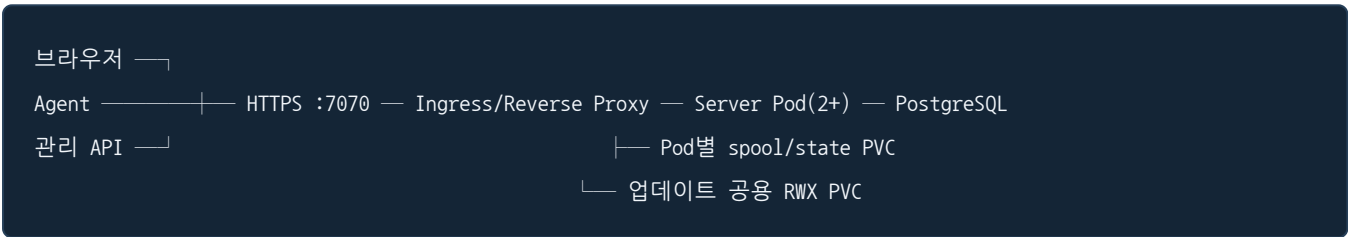


Invenqor Server 설치·운영·오프라인 배포 가이드

대상 Server 버전: v0.2.4 · Agent 버전: v0.2.2 · 기준일: 2026-07-29

1. 운영 구조와 단일 포트

Invenqor는 Linux Agent, 중앙 Server, PostgreSQL, 웹 관리 콘솔로 구성됩니다. 사용자 UI, 관리자 API, Agent 수집·heartbeat·업데이트 트래픽은 모두 Server의 기본 TCP 7070 한 포트를 공유합니다. 방화벽에는 외부 공개 포트를 여러 개 추가하지 않아도 됩니다.



운영망에서는 7070 에서 TLS를 종료하는 Ingress 또는 Reverse Proxy를 사용하고 Agent의 server.url 도 같은 URL을 지정합니다. Agent는 inbound 포트를 열지 않으며 Server로 outbound 연결만 생성합니다.

2. 무엇을 수집하고 어떻게 저장하는가

영역	주요 항목	기본 원천
시스템	호스트명, 배포판, Kernel, Architecture, Boot time, Timezone	/etc/os-release , /proc
CPU·메모리	모델, 논리 CPU, load, 메모리·swap 지표	/proc/cpuinfo , /proc/meminfo
파일시스템	장치, Mount, 유형, 옵션, 용량, inode	/proc/self/mounts , statvfs
네트워크	Interface, MAC/IP, MTU, 상태, Route, DNS, 로컬 포트	/sys/class/net , /proc/net
프로세스	PID/PPID, 이름, 상태, UID/GID, 실행 파일	/proc/[pid]
패키지	dpkg/rpm/apk 이름, 버전, Architecture	배포판 패키지 DB 또는 고정 rpm -qa
서비스	systemd/OpenRC/SysV 상태와 시작 정책	각 init 조회 인터페이스
계정	사용자·그룹, UID/GID, 홈, Shell, 보조 그룹	/etc/passwd , /etc/group
컨테이너	Runtime socket, cgroup, 컨테이너 내부 여부	Runtime·cgroup 표식

프로세스 명령행은 비밀정보가 들어갈 수 있어 기본 미수집입니다. 파일 본문, 비밀번호 해시, 환경변수, 키·토큰, 패킷 내용은 수집하지 않습니다.

Server는 `Agent UUID + category + asset_id`를 원천 키로 보관합니다. 첫 전송은 전체 Snapshot, 이후에는 `added/updated/removed` 변경분만 전송합니다. Collector 오류가 발생한 주기에는 누락을 삭제로 오판하지 않습니다. 원본 이벤트, 현재 Snapshot, 변경 이력과 오류를 함께 보존해 화면 값의 출처를 추적할 수 있습니다.

3. 온라인 Docker Compose 설치

필수 조건은 Docker Engine 24+, Compose v2, 4 GiB 이상의 여유 메모리입니다.

```
git clone https://github.com/hkjang/invenqor.git
cd invenqor
export POSTGRES_PASSWORD="$(openssl rand -base64 32)"
export BOOTSTRAP_ADMIN="admin"
export BOOTSTRAP_ADMIN_PASSWORD="CorrectHorse!42"
docker compose up -d --build
curl -fsS http://127.0.0.1:7070/health/ready
```

`http://서버:7070`에서 콘솔을 엽니다. 운영 전에는 TLS Proxy, DNS, PostgreSQL 백업, 시간 동기화와 로그 수집을 구성하십시오.

4. 폐쇄망·오프라인 설치

GitHub Release의 두 파일을 인터넷 연결 구간에서 내려받아 승인된 매체로 반입합니다.

- `invenqor-0.2.4.tar.gz`
- `invenqor-0.2.4.tar.gz.sha256`
- 함께 제공되는 `compose.offline.yaml`

무결성 검증 후 Docker에 Server와 PostgreSQL 이미지를 한 번에 적재합니다.

```
sha256sum -c invenqor-0.2.4.tar.gz.sha256
gzip -t invenqor-0.2.4.tar.gz
docker load < invenqor-0.2.4.tar.gz
docker image inspect invenqor-server:0.2.4 --format '{{.Id}} {{.Architecture}}'
docker image inspect postgres:17-alpine --format '{{.Id}} {{.Architecture}}'
```

`compose.offline.yaml`은 `pull_policy: never`이므로 외부 Registry를 조회하지 않습니다.

```
export POSTGRES_PASSWORD="$(openssl rand -base64 32)"
export BOOTSTRAP_ADMIN="admin"
export BOOTSTRAP_ADMIN_PASSWORD="CorrectHorse!42"
docker compose -f compose.offline.yaml up -d
curl -fsS http://127.0.0.1:7070/health/ready
```

반입 이미지는 `linux/amd64` 용입니다. ARM 서버에는 x86_64 이미지를 실행하지 마십시오. 제공된 빌드 스크립트는 이미지 두 개를 `docker save` 호환 gzip으로 만들고 SHA-256 파일까지 생성합니다.

```
./scripts/build-offline-images.sh 0.2.4
```

5. 최초 관리자와 Agent 등록

셸이 없는 Distroless Server image에서는 환경변수로 초기 관리자를 자동 생성하는 방식을 권장합니다. 다음 이름은 모두 지원하지만 `INVENQOR_` 접두사가 있는 이름을 표준으로 사용하십시오.

```
docker run -d --name invenqor-server \
  -p 7070:7070 \
  -v invenqor-server-state:/var/lib/invenqor-server \
  -e INVENQOR_BOOTSTRAP_ADMIN=admin \
  -e INVENQOR_BOOTSTRAP_ADMIN_PASSWORD='CorrectHorse!42' \
  invenqor-server:0.2.4
```

Compose는 호스트의 `BOOTSTRAP_ADMIN` 과 `BOOTSTRAP_ADMIN_PASSWORD` 를 위 표준 환경변수로 전달합니다. 소문자 `bootstrap_admin` , `bootstrap_admin_password` 도 직접 `docker run -e` 로 전달할 수 있습니다.

용도	표준 이름	호환 이름
관리자 ID	<code>INVENQOR_BOOTSTRAP_ADMIN</code>	<code>BOOTSTRAP_ADMIN</code> , <code>bootstrap_admin</code>
관리자 비밀번호	<code>INVENQOR_BOOTSTRAP_ADMIN_PASSWORD</code>	<code>BOOTSTRAP_ADMIN_PASSWORD</code> , <code>bootstrap_admin_password</code>
비밀번호 파일	<code>INVENQOR_BOOTSTRAP_ADMIN_PASSWORD_FILE</code>	<code>BOOTSTRAP_ADMIN_PASSWORD_FILE</code> , <code>bootstrap_admin_password_file</code>

비밀번호 값과 비밀번호 파일을 동시에 지정하면 안전을 위해 Server가 기동을 거부합니다. 비밀번호 파일 경로는 컨테이너 내부의 절대 경로여야 하며 마지막 개행 문자는 제거해서 사용합니다.

이 값은 **사용자가 한 명도 없는 최초 DB에서만** Super Admin을 생성합니다. 재시작하거나 여러 Pod가 동시에 기동해도 기존 계정과 비밀번호는 변경하지 않으며, 성공 후 일회성 Token과 DB claim을 폐기합니다. 비밀번호는 정책 검증 후 Argon2id hash로만 저장되고 로그·감사 내역에는 기록되지 않습니다.

환경변수 값은 `docker inspect` 또는 일부 운영 도구에서 보일 수 있으므로 계정 생성 후 Compose 환경에서 비밀번호를 제거하십시오. Kubernetes에서는 `INVENQOR_BOOTSTRAP_ADMIN_PASSWORD_FILE` 과 Secret volume 방식을 사용합니다.

환경변수를 사용하지 않은 경우에는 기존 일회용 Token API도 유지됩니다. Token 파일은 상태 볼륨을 마운트한 임시 진단 컨테이너에서 읽을 수 있습니다.

```
docker run --rm --volumes-from invenqor-server:ro \
  --entrypoint /bin/sh postgres:17-alpine \
  -c 'cat /var/lib/invenqor-server/initial-admin.token'
```

```
curl -X POST http://127.0.0.1:7070/api/v1/bootstrap/admin \
  -H "X-Invenqor-Bootstrap-Token: $TOKEN" \
  -H 'Content-Type: application/json' \
  -d '{"username":"admin","password":"CorrectHorse!42","display_name":"관리자"}'
```

성공 즉시 토큰은 DB에서 폐기되어 재사용할 수 없습니다.

개별 Agent UUID 등록과 장비별 Token 복사는 기본 절차가 아닙니다. 기본값은 URL-only 자동 등록입니다. Agent `config.toml` 에 Server URL만 입력하면 최초 연결에서 로컬 device claim을 만들고 장비별 Bearer Token을 발급받습니다.

```
[server]
url = "https://invenqor.example.com:7070"
ca_file = "/etc/invenqor-agent/ca.pem"
allow_insecure_http = false
timeout_seconds = 30
```

Agent는 로컬 claim과 서버가 발급한 `ivq_at_...` 장비 토큰을 `/var/lib/invenqor-agent/{enrollment-claim,device-credential}.json` 에 0600 으로 보존합니다. 응답 유실 또는 장비 토큰 무효화 시 같은 claim으로 자동 복구하며, 다른 서버 URL에는 기존 장비 토큰을 보내지 않습니다.

URL-only 모드는 Server 7070에 도달할 수 있는 장비의 최초 등록을 허용합니다. 인터넷 또는 신뢰하지 않는 네트워크에 노출하는 경우 32자 이상의 공용 Token을 설정하면 같은 자동화 흐름을 유지하면서 등록 요청을 보호할 수 있습니다.

```
export AGENT_ENROLLMENT_TOKEN="ivq_et_$(openssl rand -hex 32)"
docker compose up -d
```

Kubernetes에서는 모든 Server Pod가 같은 Secret을 읽어야 합니다. `INVENQOR_AGENT_ENROLLMENT_TOKEN_FILE` 또는 Helm `agentEnrollmentTokenSecret.name/key` 를 사용하고 Agent에도 같은 Token 파일을 배포합니다. 자동 등록 자체를 금지하려면 `INVENQOR_AGENT_AUTO_ENROLLMENT=false` 또는 Helm `agentAutoEnrollment: false` 를 사용합니다.

위 환경변수는 공용 DB에 등록 정책이 아직 없을 때의 **최초 기동 기본값**입니다. 최초 정책 생성 뒤에는 **설정 → Agent 등록** 화면의 DB 정책이 모든 Server Pod에 우선하며, 정책 변경에 재기동이나 sticky session이 필요하지 않습니다.

자동 등록을 사용하지 않는 예외 장비는 관리 화면에서 UUID를 수동 등록하고 한 번 표시되는 `bearer_token` 을 구성할 수 있습니다. 서버 DB에는 어느 방식이든 장비 Token 원문이 아닌 SHA-256 해시만 저장됩니다.

localhost, RFC1918/사설 IP, 단일-label 내부 DNS와 `.internal` / `.local` 주소의 HTTP는 URL-only 설치를 위해 자동 허용합니다. 공인 DNS의 HTTP는 `allow_insecure_http=true` 를 명시해야 하지만 격리된 E2E망 외에는 사용하지 마십시오. 신뢰 경계를 넘는 운영 연결은 HTTPS를 유지하십시오.

6. Agent 설치와 실제 기동

Release의 CPU별 정적 musl 패키지를 사용합니다. 이 방식은 CentOS 7처럼 오래된 glibc가 있는 호스트에도 별도 런타임을 요구하지 않습니다.

```
curl -fLO https://github.com/hkjang/invenqor-agents/releases/download/v0.2.2/invenqor-agent-linux-x86_64.tar.gz
curl -fLO https://github.com/hkjang/invenqor-agents/releases/download/v0.2.2/invenqor-agent-linux-x86_64.tar.gz.sha256
sha256sum -c invenqor-agent-linux-x86_64.tar.gz.sha256
tar -xzf invenqor-agent-linux-x86_64.tar.gz
sudo ./invenqor-agent-linux-x86_64/scripts/install.sh
sudoedit /etc/invenqor-agent/config.toml
sudo /opt/invenqor-agent/bin/invenqor-agent --validate-config
sudo systemctl restart invenqor-agent
sudo systemctl status invenqor-agent --no-pager
```

SysV와 OpenRC 정의도 패키지에 포함됩니다. 상태 디렉터리와 `agent-id` 는 재설치·업데이트 중 보존해야 같은 장비로 계속 인식됩니다.

7. 관리 부담을 줄이는 자동 동작

- Server는 시작 시 DB Schema를 자동 마이그레이션합니다.
- PostgreSQL 멀티 파드 마이그레이션은 advisory lock으로 한 Pod씩 수행됩니다.
- 일시적 DB 장애에는 인증된 Agent 이벤트를 Pod별 append-only spool에 쓰고 DB 복구 뒤 자동 재처리합니다.
- Agent는 변경분만 보내고, 전송 실패 시 내구성 큐와 지수 backoff로 자동 재시도합니다.
- Agent는 최초 연결에서 자동 등록하며, 장비 Token 무효화 시 로컬 claim으로 자동 재등록합니다. 관리 API의 차단은 즉시 모든 Pod에 적용됩니다.
- 서명된 업데이트는 Agent가 주기적으로 확인·검증·스테이징하고 systemd path unit이 root helper를 한 번만 호출해 원자 교체합니다.

사람이 반드시 수행할 작업은 초기 관리자, TLS/서명 개인키 보관, 백업 복구 훈련과 업데이트 승인입니다. 외부 노출 환경에서는 enrollment token의 안전한 배포·회전도 포함합니다. 개별 Agent 등록과 장비별 Token 복사는 필요하지 않습니다.

8. 서명된 Agent 자동 업데이트

업데이트 전용 Ed25519 개인키는 Server에 두지 말고 오프라인 서명 환경에 보관합니다. Agent에는 32-byte 공개키의 base64만 고정합니다.

```
openssl genpkey -algorithm ED25519 -out update-private.pem
openssl pkey -in update-private.pem -pubout -outform DER |
  tail -c 32 | base64 | tr -d '\n'
openssl pkeyutl -sign -rawin -inkey update-private.pem \
  -in invenqor-agent -out invenqor-agent.sig
base64 < invenqor-agent.sig | tr -d '\n'
```

Agent 설정:

```
[updates]
enabled = true
channel = "stable"
check_interval_seconds = 21600
public_key = "위에서-구한-base64-공개키"
install_path = "/opt/invenqor-agent/bin/invenqor-agent"
```

관리자는 `agents.manage` 권한과 CSRF Token으로 artifact, version, channel, OS, architecture, signature, rollout percentage를 `POST /api/v1/admin/agent-updates`에 multipart로 게시합니다. Agent는 자신보다 높은 버전만 받고, 인증된 단일 `7070` 연결로 다운로드합니다. 최대 128 MiB, SHA-256, 크기, OS/Architecture와 Ed25519 서명을 모두 확인한 뒤에만 `updates/pending.json`을 만듭니다. 적용 시 기존 바이너리는 `.previous`로 보존되고 원자적 rename 실패 시 즉시 복원됩니다.

Canary는 `rollout_percent`를 1~10으로 시작하고 중앙 수신·오류율을 확인한 뒤 단계적으로 100까지 올리십시오. 개인키 유출 시 즉시 배포 중단, 공개키 교체, 새 패키지 배포를 수행합니다.

9. Kubernetes 멀티 파드

필수 조건은 외부 PostgreSQL, 모든 Pod가 공유하는 32-byte Master Key Secret, Pod별 RWO state PVC, 업데이트용 RWX PVC입니다.

```
head -c 32 /dev/urandom > master.key
kubectl create secret generic invenqor-master-key --from-file=master.key
kubectl create secret generic invenqor-database \
  --from-literal=dsn='postgres://user:password@host/db?sslmode=require'
kubectl create secret generic invenqor-bootstrap-admin \
  --from-literal=password='CorrectHorse!42'
helm upgrade --install invenqor deploy/helm/invenqor \
  --set replicaCount=2 \
  --set bootstrapAdmin.username=admin \
  --set bootstrapAdmin.passwordSecret.name=invenqor-bootstrap-admin \
  --set updates.storageClassName='YOUR-RWX-STORAGE-CLASS'
```

Chart는 StatefulSet parallel 기동, readiness/liveness/startup probe, Pod anti-affinity, rolling update와 PDB `minAvailable: 1` 을 포함합니다. 세션, RBAC, Agent 상태와 감사 로그는 PostgreSQL에 있으므로 어느 Pod로 접속해도 동일합니다. Master Key가 Pod마다 다르면 암호화된 OIDC/TOTP 비밀을 해독할 수 없으므로 Secret을 교체하거나 분실하지 마십시오. RWX StorageClass가 없는 클러스터는 업데이트 공유 저장소를 별도 Object Storage 구현으로 대체하기 전까지 replica 1로 운영해야 합니다.

Chart는 관리자 비밀번호 Secret을 `/run/secrets/invenqor-bootstrap/password` 에 읽기 전용으로 마운트하고 `INVENQOR_BOOTSTRAP_ADMIN_PASSWORD_FILE` 로 읽습니다. 초기 계정 생성이 확인되면 Helm values에서 `bootstrapAdmin.username` 을 비우고 해당 Secret을 폐기하십시오.

10. 상태 확인, 백업과 복구

경로	정상 기준
<code>/health/live</code>	HTTP 200, 프로세스 생존
<code>/health/ready</code>	HTTP 200, 요청 처리 준비
<code>/health/database</code>	<code>POSTGRES_ACTIVE</code> 권장
<code>/api/v1/system/info</code>	버전 <code>0.2.4</code> , 포트 <code>7070</code> , DB 모드

백업 대상은 PostgreSQL, Pod별 state/spool PVC, 업데이트 RWX PVC와 Master Key Secret입니다. DB와 Master Key는 같은 복구 시점으로 보호하십시오. 복구 훈련은 별도 Namespace에서 로그인, Agent 재전송, 감사 로그와 update manifest까지 확인해야 완료입니다.

11. 검증된 호환성

v0.2.4 E2E는 실제 PostgreSQL-backed Server와 Agent 컨테이너를 기동하고 수집 레코드 생성, 인증 전송, DB 처리, daemon 지속 실행과 서명 업데이트 스테이징을 확인했습니다.

OS 이미지	결과
Alpine	통과
CentOS 7	통과
Red Hat UBI 8	통과
Red Hat UBI 9	통과
Ubuntu 22.04 LTS	통과
Ubuntu 24.04 LTS	통과

별도 E2E에서 Server 두 Pod를 동시에 시작해 migration, readiness, 교차 Pod 로그인 세션을 확인했습니다. 재현 명령은 `./scripts/e2e-client-server.sh` 와 `./scripts/e2e-multipod.sh` 입니다.

12. 장애 판단

- `401` : Agent UUID와 장비별 Token, 차단 여부를 확인합니다.
- TLS 오류: URL hostname, 사설 CA, 인증서 만료와 7070 경로를 확인합니다.
- 큐 증가: Server readiness와 네트워크를 복구하십시오. 큐를 임의 삭제하지 않습니다.
- `SQLITE_FALLBACK` : PostgreSQL DSN/DNS/TLS/인증을 수정하고 운영 전 PostgreSQL 모드로 재기동합니다.
- 업데이트 미적용: 공개키, signature, SHA-256, version, architecture, rollout bucket과 systemd update path unit을 확인합니다.
- 멀티 파드 일부 실패: 공통 Master Key, RWX 권한, PostgreSQL advisory lock, 해당 Pod의 state/spool PVC를 확인합니다.

13. Agent 자동 등록 설정

`settings.read` 권한은 현재 정책을 조회하고, `settings.write` 권한은 설정 → Agent 등록에서 다음 세 모드를 즉시 전환할 수 있습니다.

모드	신규 Agent 동작	권장 용도
토큰 없이 자동 등록 (<code>open</code>)	<code>config.toml</code> 의 <code>server.url</code> 만으로 최초 통신 시 등록	접근이 통제된 사내망의 Zero-touch 배포
등록 토큰 필요 (<code>token</code>)	URL과 공용 등록 Token이 모두 맞아야 최초 등록	외부 또는 신뢰 경계가 넓은 네트워크
자동 등록 비활성 (<code>disabled</code>)	신규 등록만 HTTP 403으로 거부	동결 기간·침해 대응·폐쇄 운영

Open 모드의 최소 Agent 설정은 아래와 같습니다. 사전 자산 생성, 장비별 Token 복사나 Agent 재시작 전의 별도 승인 절차는 필요하지 않습니다.

[server]

url = "https://invenqor.example.com:7070"

토큰 발급은 256-bit 등록 Token을 만들고 즉시 Token 보호 모드로 전환합니다. 같은 버튼을 다시 누르면 회전되며 구 Token은 즉시 무효화됩니다. 원문은 발급 응답과 화면에 한 번만 표시되고 DB·감사 로그에는 저장되지 않습니다. 토큰 폐기 후 자동 등록이 활성화 상태라면 Open 모드가 됩니다. 이 동작은 기존 Agent가 보유한 장비별 `ivq_at_...` Token이나 정상 수집에는 영향을 주지 않습니다.

정책은 공용 PostgreSQL의 `server_metadata`에 버전과 함께 저장됩니다. 각 등록 요청이 DB의 현재 값을 검증하므로 여러 Server Pod가 동시에 실행되어도 변경 직후 동일한 결과를 냅니다. 모든 활성화·비활성화·발급·회전·폐기는 변경 사유와 전후 상태를 감사 로그에 남기며 Token 원문과 해시는 노출하지 않습니다.

동일 기능의 관리 API는 다음과 같습니다. 상태 변경에는 관리자 Session, `X-CSRF-Token`, `settings.write`가 필요합니다.

Method	경로	기능
GET	<code>/api/v1/admin/settings/agent-enrollment</code>	현재 정책과 Token 설정 여부
PATCH	<code>/api/v1/admin/settings/agent-enrollment</code>	<code>disabled/open/token</code> 모드 적용
POST	<code>/api/v1/admin/settings/agent-enrollment/token</code>	Token 발급 또는 즉시 회전
DELETE	<code>/api/v1/admin/settings/agent-enrollment/token</code>	Token 폐기

14. PostgreSQL 설정 화면과 환경변수

Super Admin은 설정 → PostgreSQL에서 현재 DB 모드, 대상 host/port/database, schema, 설정 원천과 최근 기동 실패를 비밀번호 없이 확인할 수 있습니다. 새 DSN은 다음 순서로 처리됩니다.

1. 연결 테스트는 일회성 connect/ping만 수행하며 schema를 변경하거나 값을 저장하지 않습니다.
2. 검증 후 저장은 연결 성공 후 DSN을 `bootstrap.enc`에 AES-256-GCM으로 암호화합니다. API와 화면에는 비밀번호나 원문 DSN을 다시 반환하지 않습니다.
3. Server를 순차 재기동하면 저장값이 적용됩니다. SQLite 데이터는 자동 이관하지 않으므로 운영 데이터가 있다면 별도 백업·이관 승인이 필요합니다.
4. Kubernetes에서는 화면의 Pod 로컬 저장값 대신 모든 Pod에 동일한 Secret 환경변수를 배포하고 rolling restart 합니다.

환경변수 우선순위는 아래와 같습니다. 앞의 값이 있으면 뒤의 값과 화면 저장값을 덮어씁니다.

우선순위	이름	용도
1	<code>INVENQOR_POSTGRES_DSN</code>	권장 표준 이름
2	<code>POSTGRES_DSN</code>	Compose 호환 이름

우선순위	이름	용도
3	postgres_dsn	기존 배포 호환용 소문자 이름
4	암호화된 화면 저장값	단일 인스턴스 편의 구성

```
docker run -d --name invenqor-server \
  -p 7070:7070 \
  -e postgres_dsn='postgres://invenqor:password@db:5432/invenqor?sslmode=require' \
  -v invenqor-server-state:/var/lib/invenqor-server \
  invenqor-server:0.2.4
```

환경변수가 적용 중이면 화면에 **환경변수 우선** 경고가 표시됩니다. 이때 화면에서 다른 DSN을 저장해도 실행 중인 값은 바뀌지 않으며, 해당 환경변수를 제거하고 재기동해야 암호화 저장값이 적용됩니다.

15. Keycloak SSO/OIDC 구성

Keycloak에서는 Invenqor용 **confidential OpenID Connect client**를 만들고 Standard Flow를 활성화합니다. Direct Access Grant와 Implicit Flow는 끕니다.

Keycloak 항목	권장값
Valid Redirect URI	<code>https://invenqor.example.com/api/v1/auth/keycloak/callback</code>
Valid Post Logout Redirect URI	서비스 기본 URL
Web Origin	서비스 기본 URL
Client authentication	On
PKCE	S256

Invenqor의 **설정** → **Keycloak** 화면에서 Issuer URL, Realm, Client ID/Secret, Redirect/Logout URI, Scope, 사용자·Email·이름·역할·그룹 claim, 허용 Email domain, 기본 역할과 자동 사용자 생성을 설정합니다. 사내 TLS를 쓰면 루트/중간 CA 인증서를 PEM으로 등록할 수 있습니다.

역할과 그룹 매핑은 한 줄에 하나씩 입력합니다.

```
# Keycloak realm role = Invenqor role
inventory-admin=asset_manager
inventory-read=viewer

# Keycloak full group path = Invenqor role
/invenqor/operators=operator
/invenqor/auditors=auditor
```

Keycloak 표준 realm role을 직접 읽으려면 Role Claim에 `realm_access.roles` 를 지정할 수 있습니다. 점(.)으로 구분한 중첩 claim을 지원합니다. 별도 protocol mapper로 평면 `roles` claim을 ID Token에 넣어도 됩니다. 그룹은 Group Membership mapper에서 **Full group path**와 ID Token 포함을 활성화하십시오.

저장 전 확인 사항:

- Issuer는 HTTPS이고 discovery endpoint에 Server가 접근할 수 있어야 합니다.
- Scope에는 반드시 `openid` 가 포함되어야 합니다.
- 활성화 시 Client Secret이 필수이며 암호화 저장되고 다시 노출되지 않습니다.
- 기본 역할과 모든 mapping 대상은 실제 Invenqor 역할이어야 합니다.
- 허용 Email domain을 지정했다면 Email Claim도 필수입니다.
- **연결 테스트**는 Issuer discovery와 TLS/사설 CA 신뢰를 검증합니다.

최초 로그인은 Authorization Code + PKCE S256, State, Nonce를 검증합니다. 기존 SSO 사용자는 로그인할 때마다 프로필과 `keycloak` 원천 역할이 동기화되며, Keycloak에서 회수된 역할도 제거됩니다. 관리 콘솔에서 비활성화하거나 삭제한 계정은 같은 Keycloak subject로 자동 재생성되지 않습니다. 로컬 로그인은 비상 접근 경로로 유지하되 최소 한 개의 로컬 Super Admin을 별도로 보호하십시오. Logout Redirect URI가 설정된 SSO 사용자는 로컬 Session 폐기 후 Keycloak end-session endpoint로 이동해 IdP Session 종료도 이어서 수행합니다.

16. 사용자 관리

사용자 화면은 계정 생성, 검색, 프로필 수정, 활성화/비활성, 잠금 해제, 로컬 비밀번호 초기화, 역할 부여와 삭제를 제공합니다.

- 비밀번호 변경 시 Argon2id로 다시 hash하고 기존 세션을 모두 폐기합니다.
- 비활성화와 삭제는 사용자 Session과 해당 사용자가 만든 API key를 즉시 폐기합니다.
- 현재 로그인한 관리자는 자기 계정을 비활성화·강등·삭제할 수 없습니다.
- 마지막 활성 Super Admin은 비활성화·강등·삭제할 수 없습니다.
- `SSO` 표시 역할은 매 로그인마다 Keycloak에서 동기화되므로 콘솔에서 제거할 수 없습니다. 별도 로컬 역할만 콘솔에서 추가·회수할 수 있습니다.
- Keycloak 사용자의 비밀번호와 프로필 원본은 Keycloak에서 관리합니다.
- 모든 관리 변경은 행위자, 대상, 결과와 사유를 감사 로그에 기록합니다.